Security Incident Summary for Management

Phenomenoc network – one workstation infected with password-stealing malware (training case dated 22 June 2019)

What happened

On the evening of 22 June 2019 (about 23:48 UTC), one office computer was infected with malware while its user was browsing the web. Nothing in the recording points to email or a stolen password: simply visiting a booby-trapped web page was enough, because the computer was running an outdated Flash plug-in. Within about 20 seconds the malware had installed itself and began sending a large amount of data (about 700 kB) to a server controlled by criminals.

Key facts

Affected computer	BANGKOK-8AC2-PC (internal address 10.0.76.109)
User signed in	edris.haight
How it got in	A malicious web page secretly attacked the browser's outdated Flash plug-in (a "drive-by" attack using the RIG exploit kit) and downloaded a program
What the malware is	KPOT Stealer: software that collects saved passwords, browser data and files and uploads them to the attacker
Where the data went	An attacker-run server at 8.209.83[.]76 (website name fghjkmgru34[.]site)
Other computers	No sign that any other computer was infected. A second busy computer (Bristol-C71F-PC) was checked and cleared

Why it matters

The main risk is not the infected computer itself but what was taken from it. Passwords for email, VPN, cloud services and business systems saved on that computer should be treated as stolen. Criminals can use them to sign in as the employee, which can lead to further break-ins or fraud. We cannot see exactly what was stolen from the network record alone.

What we did

We reviewed the recorded network traffic and security alerts only. We did not run the malware, touch any live system, or scan anything. Every finding above is supported by evidence listed in the repository (evidence register, screenshots and indicator list).

What must happen now

- **Disconnect** BANGKOK-8AC2-PC from the network and rebuild it from a clean image (cleaning by hand cannot prove the malware is gone).
- **Change passwords** for the user edris.haight and for every account saved in that computer's browsers and applications; end all active sign-in sessions.
- **Block** the attacker addresses and names listed in the indicator file at the firewall and web filter.
- **Check logs** for any sign-in by this user from unusual places after 23:48 UTC and for other computers contacting the same addresses.
- **Prevent a repeat:** remove Flash, keep browsers and plug-ins updated, restrict outbound web traffic to unknown servers, and train staff to report odd pop-ups or slow computers.

How sure are we?

High confidence: which computer was infected, how the malware arrived, and where data was sent. **Medium-high confidence:** the malware family (KPOT Stealer), based on security-alert names that match its known behaviour. **Not known:** exactly which passwords or files were taken, because the data sent was not readable in the recording.